

كيف تحصل المؤسسات في العراق على شهادة ISO/IEC 27001 ؟

تتم العملية عبر شركات تدقيق ومنح شهادات معتمدة (Certification Bodies) مسجلة لدى الهيئة العراقية للاعتماد ومقبولة لدى الجهاز المركزي، ومن أبرزها :

1. الشركات العالمية العاملة في العراق :مثل *Bureau Veritas*، *TÜV*، *SGS*، و *DNV*.

2. الشركات المحلية المعتمدة :الشركات التي تمتلك توكيلاً رسمياً أو اعتماداً مسجلاً لدى الهيئة العراقية للاعتماد (IQAS) والمنتدى الدولي للاعتماد (IAF).

المسار الصحيح للحصول على الشهادة في العراق :

- التأهيل والاستشارة :التعاقد مع شركة استشارية لإعداد نظام أمن المعلومات وعمل "تحليل الفجوة" وتدريب الكوادر .
- التدقيق والتأكد من الاعتماد :اختيار جهة تدقيق مانحة للشهادة معتمدة رسمياً ومسجلة في العراق للقيام بالتدقيق الفني والإداري .
- منح الشهادة :إصدار شهادة ISO 27001 الرسمية من جهة التفيتش المعتمدة بعد إغلاق أي ملاحظات تدقيق .

خارطة طريق للحصول على شهادة ISO 27001

تتطلب عملية الحصول على شهادة ISO/IEC 27001 تطبيق نظام إدارة أمن المعلومات (ISMS) وشغل عدة مراحل تتراوح مدتها عادة بين 6 إلى 12 شهراً، وذلك بحسب حجم المؤسسة وتعقيد عملياتها.

1. المرحلة الأولى: التحضير والتخطيط: **Initial Planning** تحديد نطاق العمل والالتزام الإداري.

- دعم الإدارة العليا :الحصول على موافقة رسمية وتوفير الميزانية والموارد البشرية اللازمة.

- تحديد نطاق النظام: (Scope) تحديد أجزاء المؤسسة، الخدمات، أو الفروع التي سيشملها نطاق الشهادة (كل المؤسسة أو قسم محدد مثل قسم مركز البيانات).

- تشكيل فريق العمل: تعيين مسؤول أمن المعلومات (CISO) وفريق عمل متخصص للقيام بالمشروع.

2. المرحلة الثانية: تحليل الفجوة: Gap Analysis تقييم الوضع الحالي للمؤسسة.

- مقارنة الوضع الحالي: فحص السياسات والإجراءات المطبقة حالياً وتقييمها مقابل متطلبات معيار ISO/IEC 27001.

- تحديد النواقص: إعداد تقرير شامل يبين النقاط التي تحتاج للتطوير لتلبية المعايير.

3. المرحلة الثالثة: تقييم ومعالجة المخاطر: Risk Assessment & Treatment قلب النظام والركيزة الأساسية.

- حصر الأصول: (Asset Inventory) تسجيل كل أصول المعلومات (الأجهزة، البيانات، الموظفين، البرامج).

- تحديد التهديدات الثغرات: تحديد المخاطر التي قد تهدد هذه الأصول.

- تقييم المخاطر: حساب مستوى الخطورة والتعامل معها (تقليل، نقل، إزالة، أو قبول المخاطر).

- إعداد بيان التطبيق: (Statement of Applicability – SoA) وثيقة رسمية تحدد الضوابط التي سيتم تطبيقها وتبرير استبعاد الضوابط غير المطبقة من الملحق. (Annex A)

4. المرحلة الرابعة: بناء وتطبيق السياسات: Implementation صياغة وتفعيل الضوابط والسياسات.

- كتابة الوثائق والسياسات: تطوير سياسة أمن المعلومات، سياسة التحكم بالوصول، النسخ الاحتياطي، وإدارة الحوادث.

- تطبيق ضوابط التحكم: تطبيق الضوابط التقنية والإدارية والمادية لحماية النظام.

- التوعية والتدريب :تقديم تدريبات لجميع موظفي المؤسسة حول التهديدات السيبرانية (مثل الهندسة الاجتماعية).

5. المرحلة الخامسة: التقييم والتدقيق الداخلي: **Internal Audit** اختبار النظام قبل التدقيق الخارجي.

- التشغيل والمراقبة :تشغيل النظام لعدة أشهر لجمع الأدلة والسجلات.(Logs)
- إجراء التدقيق الداخلي :قيام فريق تدقيق (أو مستشار خارجي) بالتحقق من تطبيق النظام بدقة.
- مراجعة الإدارة :(**Management Review**) عقد اجتماع مع الإدارة العليا لمراجعة نتائج التدقيق الداخلي وأداء النظام.

6. المرحلة السادسة: التدقيق الخارجي والاعتماد: **Certification Audit** التعاقد مع جهة منح الشهادات.Manta

- المرحلة الأولى من التدقيق :(**Stage 1 Audit**) فحص الوثائق والتأكد من جاهزية المؤسسة للتدقيق الميداني.
- المرحلة الثانية من التدقيق :(**Stage 2 Audit**) فحص ميداني وتفتيش تقني من قبل المدقق الخارجي للتأكد من تطبيق كل السياسات على أرض الواقع.
- معالجة عدم المطابقة :(**Non-conformities**) إغلاق أي ملاحظات أو ثغرات يحددها المدقق الخارجي.
- منح الشهادة :إصدار شهادة ISO/IEC 27001 الرسمية وتكون صالحة لمدة 3سنوات.

7. المرحلة السابعة: التحسين المستمر والتدقيق السنوي: **Maintenance** المحافظة على صلاحية الشهادة.

- التدقيق السنوي :(**Surveillance Audits**) زيارة سنوية لجهة الاعتماد خلال السنة الأولى والثانية لضمان الاستمرارية.

- إعادة الاعتماد: (Recertification) إنجاز تدقيق شامل في نهاية السنة الثالثة لتجديد الشهادة.

توزيع المسؤوليات وفرق العمل الأساسية

- راعي المشروع: (Project Sponsor) الإدارة العليا / المدير التنفيذي (لتوفير الموارد والمصادقة على السياسات).
- مدير المشروع: (ISMS Lead Implementer) مسؤول أمن المعلومات (CISO) أو استشاري خارجي.
- فريق التنفيذ: ممثلون عن أمن المعلومات، تقنية المعلومات (IT)، الموارد البشرية (HR)، الشؤون القانونية، والعمليات.
- المدقق الداخلي: فريق مستقل من داخل المؤسسة أو طرف ثالث (لا يشارك في عملية البناء والإنشاء).

عوامل النجاح الحرجة (Critical Success Factors)

- الالتزام بالتوقيت: التركيز الشديد على التشغيل الفلي للنظام في الشهر الخامس لإيجاد الأدلة السلوكية والتقنية (Evidence) التي يطلبها المدقق الخارجي.
- فصل المهام: التأكد من أن المستشار الذي يساعد في بناء النظام لا يقوم بنفسه بعملية التدقيق النهائي لمنح الشهادة.

كيف يمكن لمجلس الإدارة قياس كفاءة تطبيق ISO 27001 عملياً؟

يقيس مجلس الإدارة كفاءة ISO 27001 عملياً من خلال 5 مؤشرات رئيسية:

1. سرعة الاستجابة للحوادث: انخفاض متوسط وقت اكتشاف واحتواء الاختراقات / (MTTD MTTR).

2. معدل خفض المخاطر: انخفاض عدد الثغرات الحرجة والمخاطر المتبقية عن الحد المقبول.

3. وعي الموظفين :هبوط نسبة السقوط في اختبارات الالتفاف والأمن (مثل رسائل الاستياد الإلكتروني).

4. نتائج التدقيق :خلو تقارير التدقيق الداخلي والخارجي من عدم المطابقة الجوهرية-Major Non Conformities).

5. جاهزية التعافي :نجاح اختبارات استمرارية الأعمال والتعافي من الكوارث ضمن الأوقات المحددة (RTO/RPO).